# Strong authentication and privileged access — Keycloak

Banque Kerlann (fictive) · Keycloak — royaume kerlann (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-12 13:07**

Auditor sign-off: **pending**
Run: **20261112-130651-keycloak-bench-meta**

Owner: **IT department — IAM team**

## 1. Executive summary

OPINION AT TESTING

**Unsatisfactory**

**Basis for opinion**

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-12 13:07, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

**Scope limitation:** Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

| | | | |
|---|---|---|---|
| **7** controls tested | **7** findings | **0** findings closed and verified | **7** open findings |
| **0** human approvals | **114** sensitive data items masked in evidence | **5 min 53 s** audit duration | **$0.458 *** measured AI cost |



Critical: 1 High: 3 Medium: 3 Low: 0

### Key messages

- 7 findings across 7 controls: 1 critical, 3 high, 3 medium.
- 7 findings remain open, with an action plan, an owner and a due date.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-2026-KC-01 |
| Entity | Banque Kerlann (fictive) |
| System | Keycloak — royaume kerlann (fournisseur d'identité) |
| System criticality | Supports critical or important functions (DORA) |
| Environment | Test Keycloak (fictitious realm) |
| Owner | IT department — IAM team |
| Lead auditor | Attest CI (automated run, no human auditor) |
| Date | 2026-11-12 13:07 |
| Framework | DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4 |

| | |
|---|---|
| Audited target | Keycloak (open-source identity provider), through the read-only gateway |
| Work programme | drafted by AI for this engagement — pending auditor review · controls/AUD-2026-KC-01.en.json |

## In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

## Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

## Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

## Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-12; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

# 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | STATUS | DUE DATE |
|---|---|---|---|---|---|---|
| F-01 | PSI-4.1 | MFA enforced for privileged administrator accounts | Critical | Non-compliant | Open | 2026-12-12 |
| F-02 | PSI-4.2 | MFA enforced for users of critical system | High | Non-compliant | Open | 2027-02-10 |
| F-03 | PSI-4.6 | Logging of administration actions | High | Non-compliant | Open | 2027-02-10 |
| F-04 | PSI-4.7 | No generic or shared administrator accounts | High | Non-compliant | Open | 2027-02-10 |
| F-05 | PSI-4.3 | Strong password policy with length and complexity | Medium | Non-compliant | Open | 2027-05-11 |
| F-06 | PSI-4.4 | Account lockout after repeated login failures | Medium | Non-compliant | Open | 2027-05-11 |
| F-07 | PSI-4.5 | Idle session timeout limited to 15 minutes | Medium | Non-compliant | Open | 2027-05-11 |

## 4. Detailed findings and controls

### F-01 PSI-4.1 MFA enforced for privileged administrator accounts

Critical · Non-compliant · Open

**CRITERIA**

Every account holding the realm role admin has multi-factor authentication configured.

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

**CONDITION**

Observed: `["a.abgrall", "b.cariou", "c.denis", "e.floch", "g.herve", "j.kermarrec", "support-n2"]`

Expected: `totp=true for every object from GET /api/kc/roles/admin/users`

Checked 7 admin accounts, 7 lack MFA.

**PROBABLE CAUSE**

MFA was likely left optional in the realm authentication configuration or administrator onboarding process. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

Without MFA, a single stolen privileged password allows full takeover of the identity provider and all connected critical functions.

**RECOMMENDATION**

Require OTP enrollment for all admin accounts and enforce MFA for the admin authentication flow.

Due date: 2026-12-12 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via paginated GET /api/kc/roles/admin/users and verify totp is true for each account.




**At testing** — The screenshot corroborates the test. All seven admin accounts show MFA as no, matching the automated test failure of 7 accounts lacking MFA. · 7/7 sensitive data items masked

`2026-11-12 13:09:31 · SHA-256 a81ff5a8a145e8c4…`

### F-02 PSI-4.2 MFA enforced for users of critical system

High · Non-compliant · Open

**CRITERIA**

Every user account in the realm, which supports critical or important functions, has multi-factor authentication

**CONDITION**

Observed: `["a.abgrall", "a.allain", "a.bertrand", "a.briand", "a.derrien", "a.floch", "a.fournier",`

configured.

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

`"a.jegou", "a.kerjean", "a.kervella", "a.le-roux", "a.lefebvre", "a.le…`

Expected: `totp=true for every object from GET /api/kc/users`

260 of 260 users have totp=false.

**PROBABLE CAUSE**

MFA was likely not made mandatory in the realm authentication flow or user lifecycle process. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

Without MFA, password-only authentication exposes critical functions to account takeover by phishing or credential stuffing.

**RECOMMENDATION**

Require OTP enrollment for all realm users and enforce MFA for the user authentication flow.

Due date: 2027-02-10 · Owner: IT department — IAM team

Test procedure: Retrieve all users via paginated GET /api/kc/users and verify totp is true for each account.

**Keycloak · kerlann** read-only audit view

## User accounts

Accounts 1–100 · 100 per page next page →

| USERNAME | REALM ROLE | ENABLED | MFA (OTP CONFIGURED) |
|---|---|---|---|
| a.abgrall | admin | yes | no |
| a.allain | — | yes | no |
| a.bertrand | — | yes | no |
| a.briand | — | yes | no |
| a.derrien | — | yes | no |
| a.floch | — | yes | no |
| a.fournier | — | yes | no |
| a.jegou | — | yes | no |
| a.kerjean | — | yes | no |
| a.kervella | — | yes | no |
| a.le-roux | — | yes | no |
| a.lefebvre | — | yes | no |
| a.lefloch | | yes | no |
| a.madec | | yes | no |
| a.mercier | — | yes | no |
| a.pennec | — | yes | no |
| a.quere | — | yes | no |
| a.quere2 | — | yes | no |
| a.quillien | — | yes | no |
| a.raoul | — | yes | no |
| a.robert | — | yes | no |
| a.roux | — | yes | no |
| a.roux2 | — | yes | no |
| b.bihan | — | yes | no |
| b.bonnet | — | yes | no |
| b.cariou | admin | yes | no |
| b.cloarec | — | yes | no |
| b.dupont | — | yes | no |
| b.even | — | yes | no |
| b.kerbrat | — | yes | no |
| b.kerjean | — | yes | no |
| b.madec | — | yes | no |
| b.morel | — | yes | no |
| b.quillien | — | yes | no |
| b.roux | — | yes | no |
| b.uguen | — | yes | no |
| c.abgrall | | yes | no |
| c.bertrand | | yes | no |
| c.denis | admin | yes | no |
| c.durand | — | yes | no |
| c.floch | — | yes | no |
| c.guillou | — | yes | no |
| c.jacq | — | yes | no |
| c.lagadec | — | yes | no |
| c.lambert | — | yes | no |
| c.le-bihan | | yes | no |
| c.leroy | — | yes | no |
| c.madec | — | yes | no |
| c.guillien | | yes | no |

| | | | |
|---|---|---|---|
| c.quillien | — | yes | no |
| c.quillien2 | — | yes | no |
| c.raoul | — | yes | no |
| c.raoul2 | — | yes | no |
| c.robert | — | yes | no |
| c.roux | — | yes | no |
| c.uguen | — | yes | no |
| d.jaouen | — | yes | no |
| d.madec | — | yes | no |
| d.martin | — | yes | no |
| d.roux | — | yes | no |
| e.david | — | yes | no |
| e.dubois | — | yes | no |
| e.floch | admin | yes | no |
| e.girard | — | yes | no |
| e.le-gall | — | yes | no |
| e.le-gall2 | — | yes | no |
| e.lefloch | — | yes | no |
| e.michel | — | yes | no |
| e.morel | — | yes | no |
| e.nedelec | — | yes | no |
| e.petit | — | yes | no |
| e.robert | — | yes | no |
| e.salaun | — | yes | no |
| e.tanguy | — | yes | no |
| e.toullec | — | yes | no |
| e.vincent | — | yes | no |
| e.vincent2 | — | yes | no |
| f.daniel | — | yes | no |
| f.guillou | — | yes | no |
| f.kerjean | — | yes | no |
| g.bernard | — | yes | no |
| g.bertrand | — | yes | no |
| g.even | — | yes | no |
| g.gourvennec | — | yes | no |
| g.henaff | — | yes | no |
| g.herve | admin | yes | no |
| g.kerjean | — | yes | no |
| g.lambert | — | yes | no |
| g.lambert2 | — | yes | no |
| g.laurent | — | yes | no |
| g.lefloch | — | yes | no |
| g.morel | — | yes | no |
| g.petit | — | yes | no |
| g.richard | — | yes | no |
| h.gourvennec | — | yes | no |
| h.le-roux | — | yes | no |
| h.moreau | — | yes | no |
| h.robert | — | yes | no |
| i.girard | — | yes | no |
| i.gourmelen | | yes | no |
| i.jaouen | — | yes | no |

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

**At testing** — The screenshot corroborates the test. All 100 visible user rows show MFA (OTP CONFIGURED) as no, consistent with the automated finding that 260 of 260 users have totp=false. · 100/100 sensitive data items masked (94 spotted by the AI, the rest by the deterministic safety net)

`2026-11-12 13:12:13 · SHA-256 831d74a4a7e641f4…`

### F-03 PSI-4.6 Logging of administration actions

High · Non-compliant · Open

**CRITERIA**

All administration actions are recorded as admin events in the realm.

PSI-4.6 · RTS 12(2)(c)(i)

**CONDITION**

Observed: `false`

Expected: `adminEventsEnabled=true`

Realm representation reports adminEventsEnabled=false, so administration actions are not recorded.

**PROBABLE CAUSE**

Admin event logging was likely never enabled during realm hardening. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

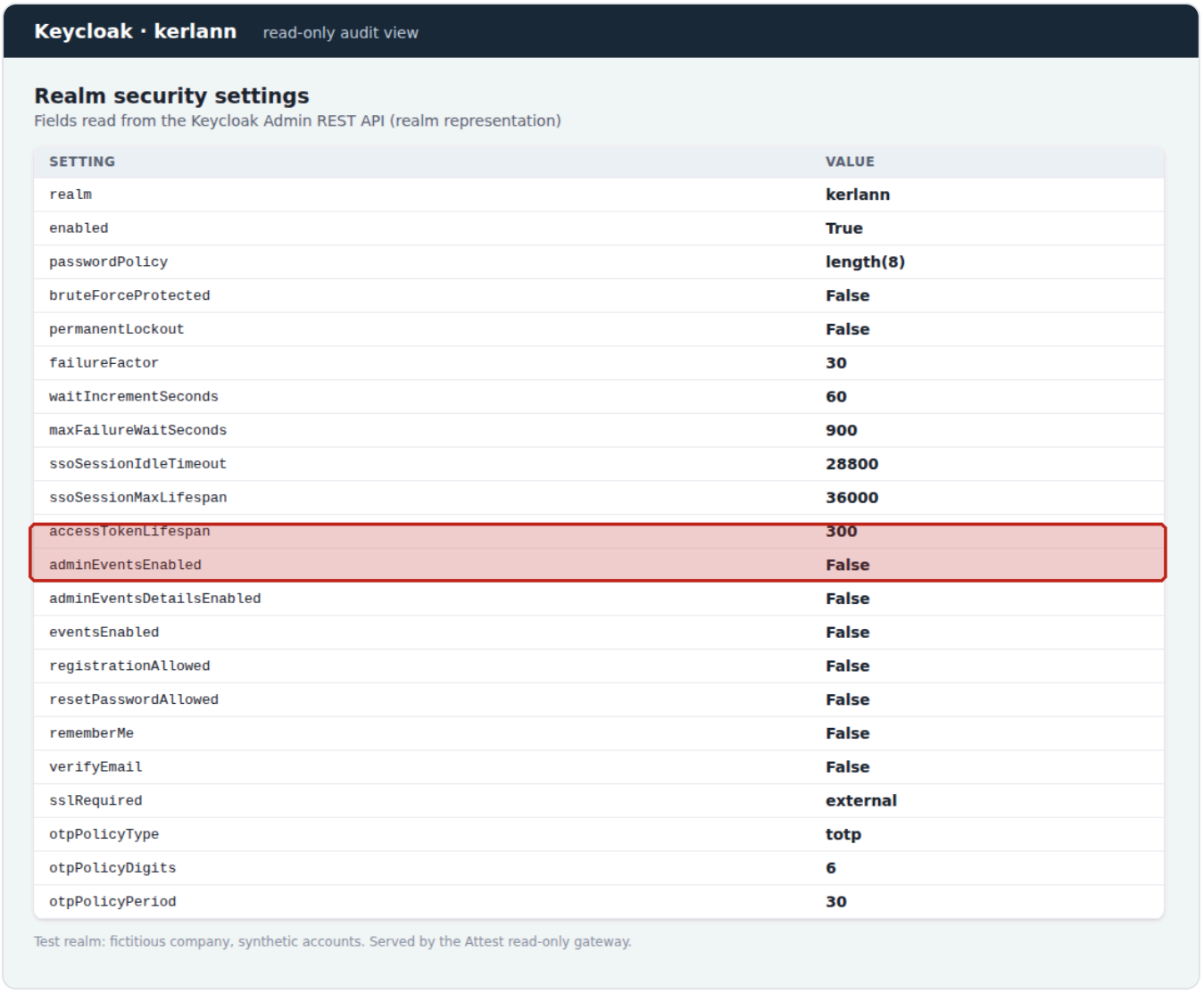
Without admin audit logging, malicious or erroneous privileged changes cannot be detected, investigated or attributed.

**RECOMMENDATION**

Enable admin events recording in the realm and retain the logs in the central SIEM.

Due date: 2027-02-10 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and verify adminEventsEnabled is true.




**At testing** — The screenshot corroborates the test. The screenshot shows adminEventsEnabled as False, matching the automated test failure.
`2026-11-12 13:12:13 · SHA-256 7fb90aeb38941b5a…`

### F-04 PSI-4.7 No generic or shared administrator accounts

High | Non-compliant | Open

**CRITERIA**

No holder of the realm role admin is a generic or shared account, with each admin having a nominative username of form initiale.nom and a personal email.

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

**CONDITION**

Observed: `["support-n2"]`
Expected: `username matches initiale.nom pattern and email is personal (not ops, admin, root or ops-partage@, admin@) for every object from GET /api/kc/roles/admin/users`

Checked 7 admin users, found 1 with generic or non-nominative username or email.

**PROBABLE CAUSE**

Operational convenience likely led to creation of function accounts with admin rights without enforcing nominative provisioning. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

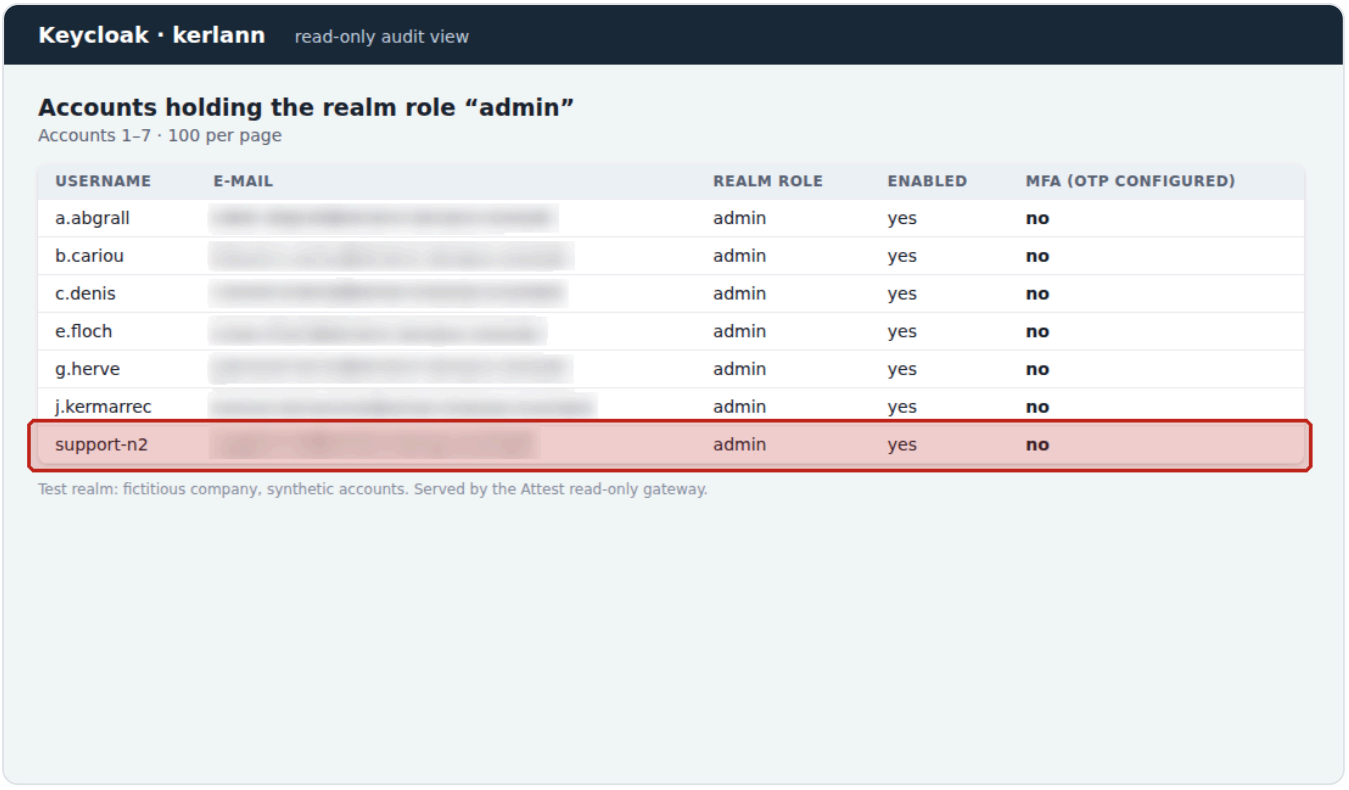
Shared privileged accounts destroy accountability and allow uncontrolled, non-attributable administrator access.

**RECOMMENDATION**

Remove admin rights from all generic or shared accounts and replace them with nominative accounts.

Due date: 2027-02-10 · Owner: IT department — IAM team

Test procedure: Retrieve all members of the realm role admin via paginated GET /api/kc/roles/admin/users and verify username and email are nominative and not function or shared-mailbox values.




**At testing** — The screenshot corroborates the test. Screenshot shows seven admin accounts including generic account support-n2 with non-nominative username and email. · 7/7 sensitive data items masked

`2026-11-12 13:13:22 · SHA-256 5322bb14a0246676…`

## F-05 PSI-4.3 Strong password policy with length and complexity

Medium | Non-compliant | Open

### CRITERIA

The realm passwordPolicy requires minimum length of 12 characters with complexity requirements.

PSI-4.3 · DORA 9(4)(d)

### CONDITION

Observed: `length(8)`

Expected: `passwordPolicy contains length(12) or greater and upperCase(1), lowerCase(1), digits(1) and specialChars(1)`

Realm password policy does not satisfy length 12 or greater with upper-case, lower-case, digit and special-character requirements.

### PROBABLE CAUSE

The realm password policy was likely left at Keycloak defaults and never hardened to the internal standard. (AI hypothesis, not tested: to be confirmed with the owner)

### RISK

Weak passwords can be guessed or brute-forced, leading to unauthorized access to critical identity services.

### RECOMMENDATION

Set the realm password policy to enforce at least 12 characters with upper-case, lower-case, digit and special-character complexity.

Due date: 2027-05-11 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and parse passwordPolicy to verify length and complexity items are present.

**Keycloak · kerlann** read-only audit view

### Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

| SETTING | VALUE |
|---|---|
| realm | **kerlann** |
| enabled | **True** |
| passwordPolicy | **length(8)** |
| bruteForceProtected | **False** |
| permanentLockout | **False** |
| failureFactor | **30** |
| waitIncrementSeconds | **60** |
| maxFailureWaitSeconds | **900** |
| ssoSessionIdleTimeout | **28800** |
| ssoSessionMaxLifespan | **36000** |
| accessTokenLifespan | **300** |
| adminEventsEnabled | **False** |
| adminEventsDetailsEnabled | **False** |
| eventsEnabled | **False** |
| registrationAllowed | **False** |
| resetPasswordAllowed | **False** |
| rememberMe | **False** |
| verifyEmail | **False** |
| sslRequired | **external** |
| otpPolicyType | **totp** |
| otpPolicyDigits | **6** |
| otpPolicyPeriod | **30** |

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

**At testing** — The screenshot corroborates the test. The screenshot shows passwordPolicy as length(8), which lacks the required length 12 and complexity items.

`2026-11-12 13:10:24 · SHA-256 0da5a4d8e337ab90…`

## F-06 PSI-4.4 Account lockout after repeated login failures

Medium · Non-compliant · Open

**CRITERIA**

Account lockout on repeated login failures is enabled and triggers after at most 5 failures.

PSI-4.4 · DORA 9(4)(c)

**CONDITION**

Observed: `{"bruteForceProtected": false, "failureFactor": 30}`

Expected: `bruteForceProtected=true and failureFactor<=5`

Checked 1 realm; bruteForceProtected is false and failureFactor is 30.

**PROBABLE CAUSE**

Brute-force protection was likely never enabled or was configured with a permissive threshold. (AI hypothesis, not tested: to be confirmed with the owner)

**RISK**

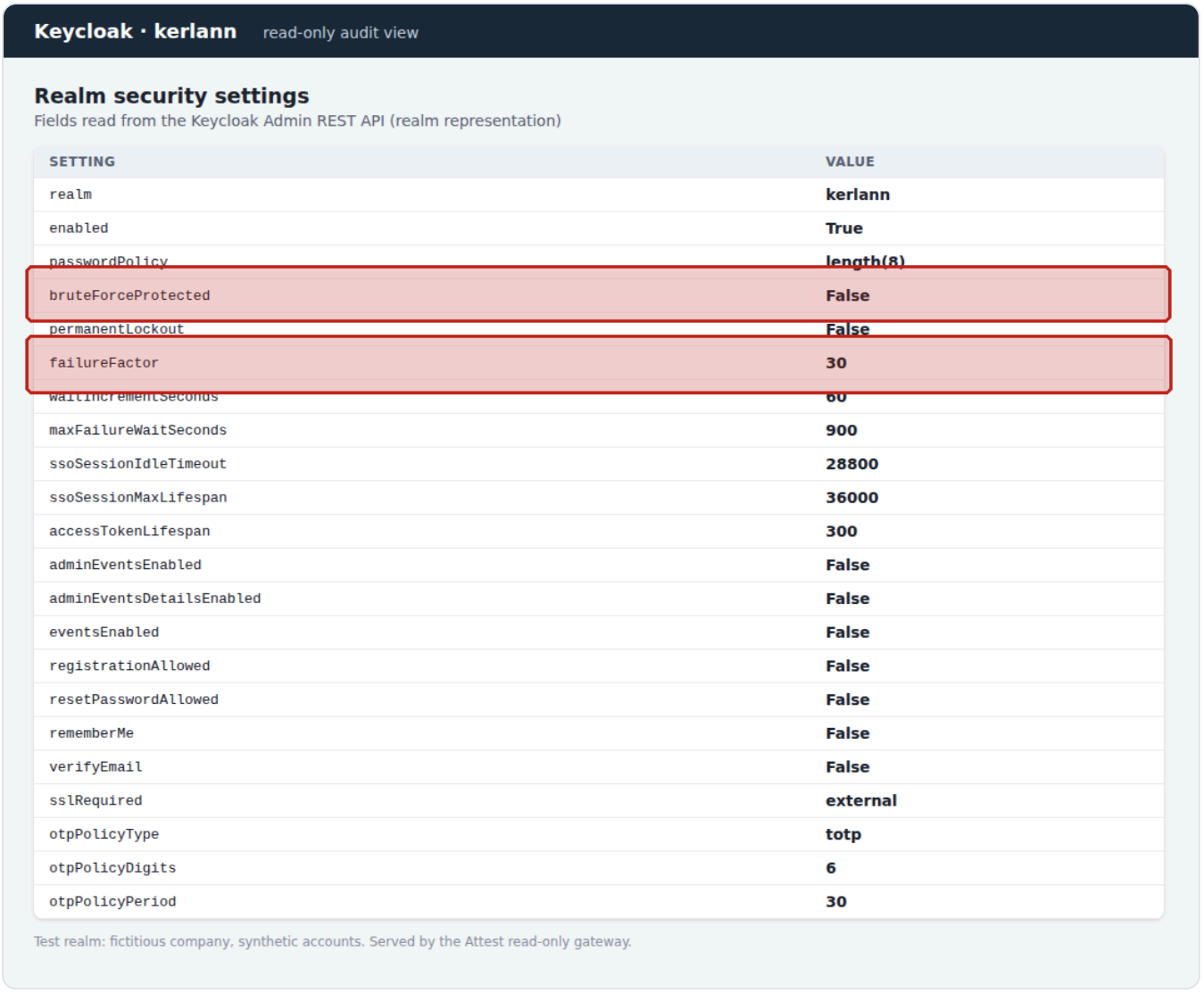
Without lockout, attackers can perform unlimited online password-guessing attacks against all accounts.

**RECOMMENDATION**

Enable brute-force protection in the realm and set the failure threshold to 5 or fewer attempts.

Due date: 2027-05-11 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and verify bruteForceProtected is true and failureFactor is less than or equal to 5.




**At testing** — The screenshot corroborates the test. Screenshot shows bruteForceProtected is False and failureFactor is 30, matching the automated failure.
`2026-11-12 13:10:05 · SHA-256 0fb1d09d20e66857…`

## F-07 PSI-4.5 Idle session timeout limited to 15 minutes

Medium | Non-compliant | Open

### CRITERIA

Idle SSO sessions expire after at most 15 minutes and idle timeout is not disabled.

PSI-4.5 · DORA 9(4)(c)

### CONDITION

Observed: `28800`

Expected: `ssoSessionIdleTimeout<=900 (seconds) and not disabled or zero`

Realm ssoSessionIdleTimeout is 28800 seconds, exceeding the 900-second limit.

### PROBABLE CAUSE

The realm session timeout was likely left at the Keycloak default value exceeding 15 minutes. (AI hypothesis, not tested: to be confirmed with the owner)

### RISK

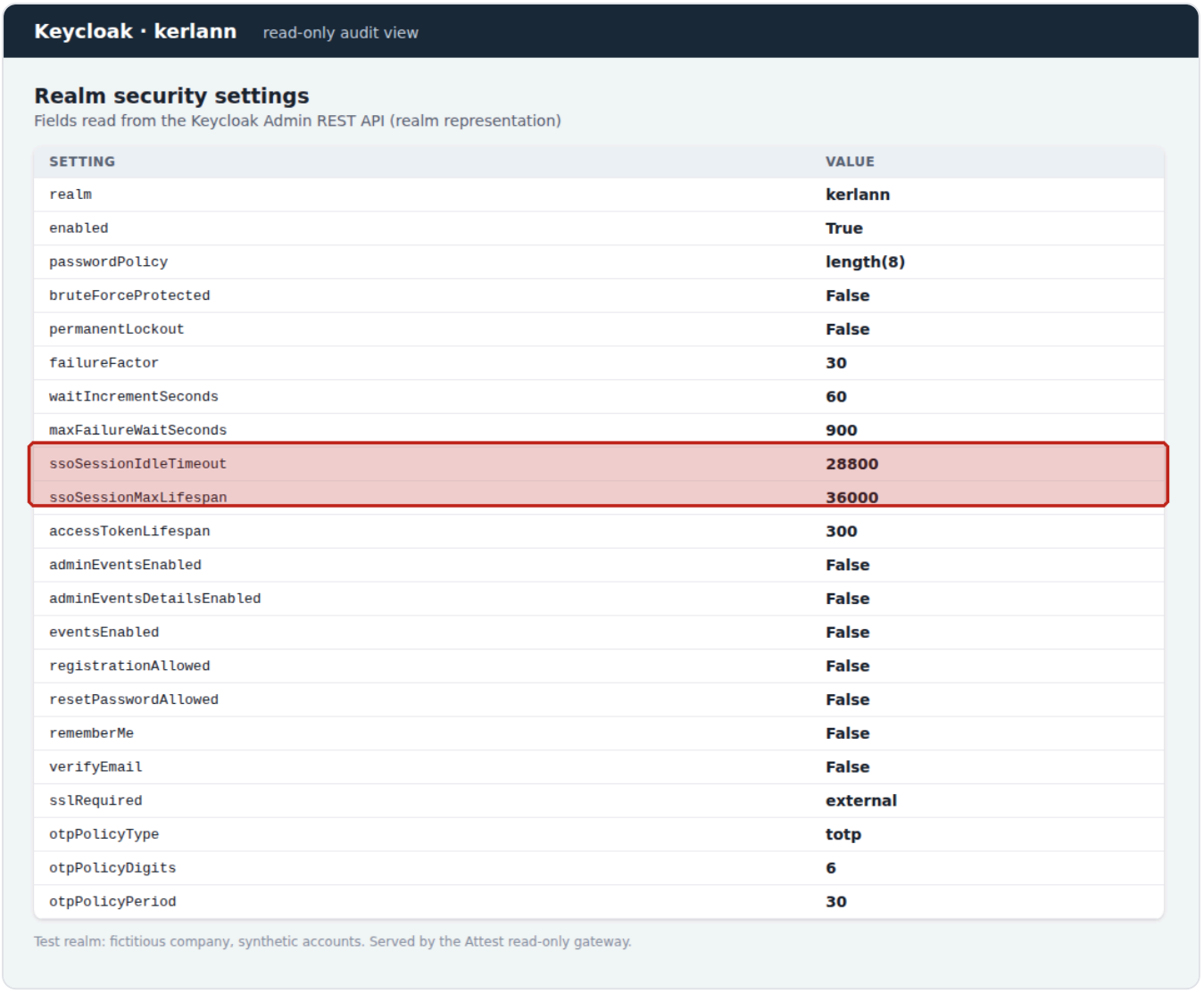
Overly long idle sessions allow session hijacking and unauthorized use of unattended workstations.

### RECOMMENDATION

Set the realm idle session timeout to 900 seconds or less.

Due date: 2027-05-11 · Owner: IT department — IAM team

Test procedure: Retrieve GET /api/kc/realm and verify ssoSessionIdleTimeout is set to 900 seconds or less.




**At testing** — The screenshot corroborates the test. Screenshot shows ssoSessionIdleTimeout is 28800 seconds, exceeding the 900-second limit.

`2026-11-12 13:11:45 · SHA-256 cd2e6cf4cef2c93e…`

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.1 | C1 · MFA enforced for privileged administrator accounts | 9fa33ed1913fff99 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.2 | C2 · MFA enforced for users of critical system | a3a93c09f9e4841e · written by AI for this engagement | Non-compliant |
| DORA 9(4)(d) | PSI-4.3 | C3 · Strong password policy with length and complexity | f68b831a9eaf64e1 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(c) | PSI-4.4 | C4 · Account lockout after repeated login failures | c9a1e15280e49977 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(c) | PSI-4.5 | C5 · Idle session timeout limited to 15 minutes | 8f2905c677d55721 · written by AI for this engagement | Non-compliant |
| RTS 12(2)(c)(i) | PSI-4.6 | C6 · Logging of administration actions | 90d35a527b9a83dd · written by AI for this engagement | Non-compliant |
| DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii) | PSI-4.7 | C7 · No generic or shared administrator accounts | abb50391184fc2ef · written by AI for this engagement | Non-compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-12 13:09:31 | a81ff5a8a145e8c436141ee04c06b139c86076eaff12c2ff5654f3bc225abc44 |
| evidence/C2_before.png | C2 · At testing | 2026-11-12 13:12:13 | 831d74a4a7e641f43c85153ce8acd30aba2db0ee419e8dd035333065e5fcfd6d |
| evidence/C3_before.png | C3 · At testing | 2026-11-12 13:10:24 | 0da5a4d8e337ab901abf295d28d1a8ec74737e4d04fac90de5b934dfd080f61a |
| evidence/C4_before.png | C4 · At testing | 2026-11-12 13:10:05 | 0fb1d09d20e66857909336e66ccb6df9e13b2dea5c18c6d931772729ac82caca |
| evidence/C5_before.png | C5 · At testing | 2026-11-12 13:11:45 | cd2e6cf4cef2c93ef120ff47347508bf7d002dff5562f265d863eb06972b122c |
| evidence/C6_before.png | C6 · At testing | 2026-11-12 13:12:13 | 7fb90aeb38941b5aaf6c90b781babc58cb0043350ec28e372da0ba552fa00a82 |
| evidence/C7_before.png | C7 · At testing | 2026-11-12 13:13:22 | 5322bb14a0246676e6b945d81b536ef92f7cba14609f04291ccd9a1b685bb8c8 |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|

| | | | | | |
|---|---|---|---|---|---|
| `muse-spark-1.3` | 15 | 29,065 | 99,157 | 0 | 0.4577 |
| `sam-3.1` | 19 | 0 | 0 | 19 | price not published |
| **Total** | | | | | **0.4577** |

Sensitive data (personal data and secrets) in evidence: 108/114 spotted by Muse Spark + SAM, 114/114 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

## Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`f1cbd179564e87fab205b633d542af0ca863a3ee0fdbe08ab8a956b6755a1850`